

CERTIGHOST AD CS CHASE TO NON-DC

A network-telemetry validation model for Certificate Authority SMB and LDAP connections to requester-controlled hosts.

VALIDATION

CONFIDENCE: MEDIUM



REPORT DATE

25 July 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceNetworkEvents

ATT&CK TACTICS

Privilege Escalation ·
Credential Access

Operational research dossier. All implementations are untested sketches and require target-environment validation.

01

EXECUTIVE ASSESSMENT

Decision-grade summary for SOC and detection engineering.

ASSESSMENT LAYER

EXECUTIVE SUMMARY

Certighost AD CS Chase to Non-DC

The researchers demonstrated that an unpatched Enterprise Certification Authority follows requester-supplied cdc routing data and opens SMB/LSA and LDAP connections to an attacker-controlled host. The hostile endpoint returns Domain Controller identity data that influences certificate issuance.

WHY IT MATTERS

Operational value 9.1 / 10

Outbound TCP/445 or TCP/389 from a known CA to a host that is not an approved Domain Controller is a direct prerequisite of the demonstrated chase-abuse path. It is valuable for validation, but a network match alone does not prove certificate forgery.

Medium 01

CONFIDENCE



9.1 02

OPERATIONAL VALUE



Validation 03

READINESS



SOURCE-CONFIRMED FACTS

- The PoC directs the CA to an attacker-controlled cdc target.
- The CA opens SMB/LSA and LDAP connections to that target.
- The tested chain can issue a certificate carrying Domain Controller identity material.

ANALYTICAL ASSESSMENT

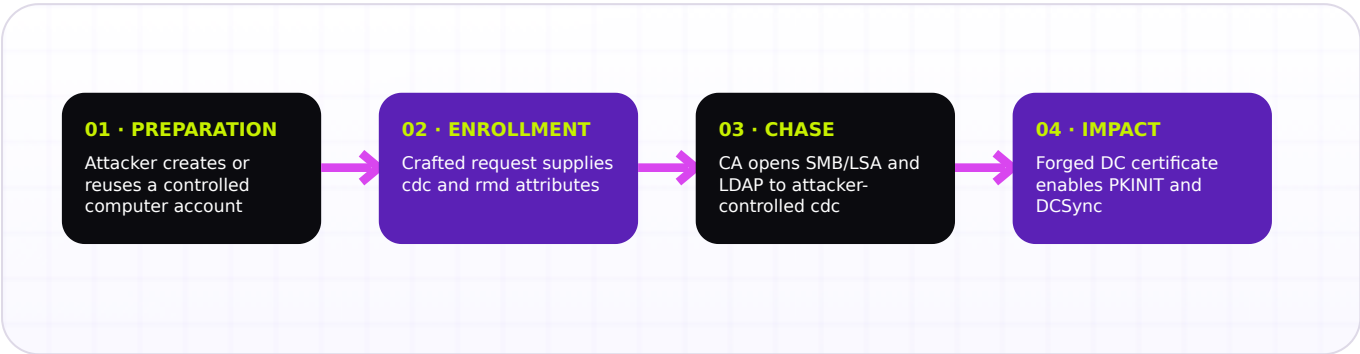
- CA-to-non-DC SMB/LDAP is the strongest cross-environment network observable in the public analysis.
- The query should validate exposure and benign overlap before any alert is considered.
- Certificate issuance and PKINIT evidence remain necessary to confirm successful exploitation.

ASSUMPTIONS

- All Enterprise CA hosts are explicitly listed in the query.
- All legitimate Domain Controller IP addresses are represented in the environment allowlist.
- DeviceNetworkEvents records outbound CA connections without material sensor gaps.

THREAT MECHANICS

Source-observed chain and detection value.



THREAT MECHANICS AND VISIBILITY

STAGE	BEHAVIOR	OBSERVABLE EVIDENCE	VALUE
Preparation	Attacker creates or reuses a controlled computer account	Directory account-change telemetry	Medium
Enrollment	Crafted request supplies cdc and rmd attributes	CA request content is not assumed available	Low
Chase	CA opens SMB/LSA and LDAP to attacker-controlled cdc	CA network telemetry	High
Impact	Forged DC certificate enables PKINIT and DCSync	Certificate, Kerberos and directory-replication logs	Medium

Evidence boundary

The report does not infer unseen payload content or compromise outcome. Every query targets the directly observable behavior identified above.

TELEMETRY AND EVIDENCE MODEL

Required data, fields and visibility constraints.

PRIMARY DATA SOURCE

Microsoft Defender XDR - DeviceNetworkEvents

The selected platform provides the most direct observable for the behavior. Optional enrichment must not be treated as guaranteed.

REQUIRED QUALITY

Complete raw values and stable entity context

Retention, truncation, parsing and sensor coverage must be confirmed before operational deployment.

REQUIRED FIELDS

FIELD	RELIABILITY	PURPOSE
Timestamp	Documented	Network-event time
DeviceId / DeviceName	Documented	Explicit CA host scoping
RemoteIP	Documented	Compare with approved DC addresses
RemotePort	Documented	Source-observed TCP/445 and TCP/389
RemoteUrl	Documented	Optional destination context
InitiatingProcessFileName	Documented	Optional process enrichment; not filtered

Required

The primary event, host identity and directly filtered values.

Optional enrichment

Signer, prevalence, parent lineage, network activity or ownership context when available.

DETECTION LOGIC

Primary-platform implementation and condition rationale.

UNTESTED SKETCH

DETECTION OBJECTIVE

Certighost AD CS Chase to Non-DC

Surface the source-observed behavior with the minimum defensible conditions.

STATUS

Validation - Untested implementation sketch

No query in this dossier has been executed in the target environment.

KQL · DEMONSTRATIVE

```
// Replace the environment-specific values before execution.
let EnterpriseCAHosts = dynamic(["<CA_FQDN>"]);
let ApprovedDomainControllerIPs = dynamic(["<DC_IP_1>", "<DC_IP_2>"]);
DeviceNetworkEvents
| where DeviceName in~ (EnterpriseCAHosts)
| where RemotePort in (389, 445)
| where RemoteIP !in (ApprovedDomainControllerIPs)
| project Timestamp, DeviceId, DeviceName, RemoteIP,
    RemotePort, RemoteUrl, Protocol, ActionType,
    InitiatingProcessFileName, InitiatingProcessCommandLine,
    ReportId
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

WHY EACH CONDITION EXISTS

CONDITION	REASON
Enterprise CA scope	Limits the validation to explicitly inventoried CA hosts.
Remote ports 389 and 445	Matches the LDAP and SMB/LSA chase traffic demonstrated by the researchers.
Approved DC exclusion	Tests the core deviation: CA chase traffic to a non-approved DC address.
No process filter or threshold	The source does not prove a universal process mapping or justify aggregation.

05

TRIAGE AND INVESTIGATION

Evidence collection and disposition workflow.

SOC WORKFLOW

01

Confirm telemetry

Replace the CA and Domain Controller placeholders using the authoritative asset inventory.

02

Reproduce safely

Run over 30 days and collect every distinct RemoteIP, port, process and ActionType.

03

Investigate context

Reproduce an authorized CA-to-test-host connection and confirm DeviceNetworkEvents coverage.

04

Apply decision gate

Reject promotion if legitimate non-DC SMB/LDAP remains indistinguishable or inventory cannot be maintained.

INVESTIGATION PIVOTS

Host · user · process · file · network · identity

- Validate actor or parent identity.
- Collect full raw event and surrounding timeline.
- Confirm software owner and change context.
- Review adjacent endpoint, identity and network evidence.
- Preserve hashes and stable event identifiers.



FALSE POSITIVES AND VALIDATION

Baseline, test plan and operational promotion gate.

FALSE-POSITIVE MATRIX

EXPECTED OVERLAP	LIKELIHOOD	TUNING ACTION
Legitimate CA access to member servers	Environment-dependent	Identify service owner and protocol purpose before exclusion.
Incomplete DC inventory	High	Reconcile all DC interfaces, IPv4/IPv6 addresses and site changes.
Network-address translation	Medium	Validate what RemoteIP represents at the endpoint sensor.
Sensor or retention gaps	Medium	Run a controlled CA connection test and confirm event capture.

SUCCESS CRITERIA

Candidate can be separated from authorized activity

CA egress to TCP/389 or TCP/445 is visible, approved DC destinations are complete, and non-DC results are rare and attributable.

REJECTION CRITERIA

Do not promote when evidence remains ambiguous

CA hosts or Domain Controllers cannot be scoped reliably, or routine non-DC traffic cannot be separated from the exploit prerequisite.

Promotion gate

Require representative baseline, preserved field semantics, documented exclusions, reproducible tests and analyst-readable output. Otherwise retain the current classification.

ATT&CK, CONCLUSION AND REFERENCES

Coverage summary, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	EVIDENCE BASIS
T1649	Steal or Forge Authentication Certificates	Mapped only to the directly observed behavior.

ANALYST CONCLUSION

Certighost AD CS Chase to Non-DC

This validation query captures a source-demonstrated prerequisite without claiming successful exploitation. It is suitable for exposure assessment and event collection; promotion requires certificate, authentication and replication evidence.

Residual risk

Telemetry gaps, altered attacker artifacts and authorized behavior can reduce precision. A query match is an investigative lead, not proof of compromise or attribution.

REFERENCES

- 1. H0j3n and Aniq Fakhrul, "Certighost (CVE-2026-54121)," 24 July 2026.
<https://gist.github.com/H0j3n/a5ef2609b5f2944ac2390a191a534c26>
- 2. Official platform documentation.
<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-devicenetworkevents-table>
- 3. MITRE ATT&CK Enterprise technique T1649.
<https://attack.mitre.org/techniques/T1649/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	CHANGE SUMMARY
v1.0	25 July 2026	Validation · Medium	Initial evidence-led dossier; untested implementation sketch.